CISSP
Comprehensive Study Guide

Domains 1–8 · Models · Processes · Frameworks

Based on Pete Zerger's Exam Cram & Personal Notes

- Domain 1 — Security & Risk Management
- Domain 2 — Asset Security
- Domain 3 — Security Architecture & Engineering
- Domain 4 — Network Security
- Access Control & AAA Protocols
- Security Models · Frameworks · Lifecycles

Table of Contents

1. Enterprise Governance, Strategy & Management 3
2. Organizational Structure, Roles & RACI 4
3. Information Security Strategy & Planning 5
4. Governance Frameworks — COBIT, BMIS, Balanced Scorecard 6
5. Access Control, AAA & Accountability 7
6. Authentication & Authorization Protocols 8
7. Risk Management — Concepts, Formulas & Processes 10
8. Threat Modeling — STRIDE, PASTA, DREAD, VAST, TRIKE 12
9. Business Continuity & Disaster Recovery 13
10. NIST Frameworks — RMF (800-37) & CSF 14
11. ISO/IEC Standards Quick Reference 15
12. Data Classification — Government & Private Sector 16
13. Security Models — BLP, Biba, Clark-Wilson & More 17

14. Common Criteria & Evaluation Standards 19
15. Key Lifecycles — Data, SDLC, IAM, Incident Response 20
16. Capability Maturity Models — CMM, SAMM, IDEAL 22
17. OSI Model & Network Protocols 23
18. Key Standards Quick Reference 24
19. Formulas, Mnemonics & Exam Tips 25

Domain 1A — Enterprise Governance & Strategy

Governance → Strategy → Management

NOTE: Governance sets the WHY/WHAT. Strategy defines HOW (high-level). Management EXECUTES the how. This is a top-down model: Board → Senior Mgmt → CISO → day-to-day operations.

Governance vs. Strategy vs. Management

Layer	Focus	Owned By	Key Activities
Governance	Sets the "why & what". Establishes risk appetite, policies, standards, frameworks.	Board of Directors / Senior Mgmt	Define risk appetite; approve policies; oversight committees
Strategy	Defines "how" at a high level. Roadmap from current → desired state.	CISO / Senior Mgmt	Current state assessment; gap analysis; initiative roadmap
Management	Executes the "how". Day-to-day operations, monitoring, controls.	Security Managers / Operations	Implement controls; manage operations; monitor risk tolerance

Six Outcomes of Information Security Governance

Outcome	Description	Key Measure
Strategic Alignment	Security investments map to and support business strategy	Business objectives vs. security controls mapping
Risk Management	Risks are kept within the organization's risk tolerance	Risk register; ALE calculations; risk treatment records
Value Delivery	Security investments contribute measurable bottom-line benefit	Cost savings; reduced incident losses; ROI on controls
Resource Optimization	People, budget, and tools are allocated efficiently	Budget utilization; staff-to-asset ratios; tool coverage
Performance Measurement	KPIs, KRIs, and metrics demonstrate program effectiveness	KPI dashboards; audit scores; compliance %
Assurance Integration	Audits and compliance woven in — security is not siloed	Audit findings closure rate; integrated assurance coverage

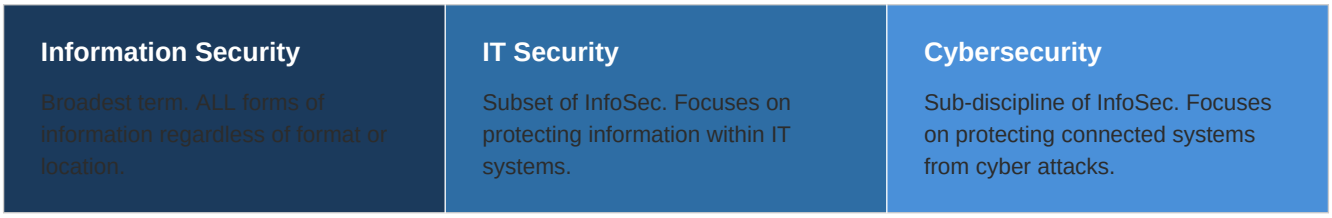
Enterprise Governance vs. Information Security Governance

Enterprise Governance	Overall framework of rules, policies, standards & procedures that direct, monitor, and control ALL activities. Covers objectives, vision, mission, org structure, leadership.
IS Governance	Specialized subset focused on protecting information assets. Ensures security policies integrate into business processes. Leverages enterprise governance to embed security everywhere.
Planning Horizons	Strategic (3-5 yr) → Tactical (1-2 yr) → Operational (daily/weekly). Security programs must align across all three horizons.
Security Charter	Specifies who has authority to act, what they are responsible for, and why the InfoSec program exists. Most orgs have one charter covering both governance and operational aspects.

Security Governance Principles

Vision	What does the org aspire to deliver? Aspirational statement of future security posture. Example — Microsoft: "To democratize AI, making it accessible and beneficial for everyone."
Mission	Why do we do what we do? Core purpose in implementing security and identifying key stakeholders being served. Example — Microsoft: "To empower every person and org to achieve more."
Strategic Objectives	Specific, measurable, time-bound goals outlining the path toward achieving the security vision while aligning with org policies.
KPIs	Measurable metrics demonstrating progress toward strategic security objectives. The "how do we know we achieved it" question.

Three Circles of Security



Domain 1A — Organizational Structure, Roles & Responsibilities

Key Executive Roles

Role	Responsibilities	Reports To
Board of Directors	Highest governing body. Sets risk appetite. Fiduciary duty to shareholders. Selects CEO. Forms oversight committees. ACCOUNTABLE for org success.	Shareholders
CEO	Top executive. Implements board directives. Oversees risk mgmt, assets, budget, personnel. Develops governance functions.	Board of Directors
CISO	Owns InfoSec program & strategy. Develops/enforces security policies. Manages risk programs. Oversees security ops. Ensures security aligns with business goals.	CEO / CFO (varies)
CPO	Owns privacy program. PII oversight. Consumer privacy advocacy. Coordinates with CISO on information protection.	CEO / Legal
CRO	Enterprise risk management including InfoSec risks. Mitigates business risks. Minimizes fraud (especially in banking).	CEO / Board
Business Process Owners	Management-level. Oversee business processes relying on IT. Make key business decisions impacting access control and process leadership.	Various Senior Mgmt
Steering Committee	Cross-functional group with senior members. Ensures stakeholders impacted by security are considered. Communication bridge between security and business.	CISO / Senior Mgmt

Accountability vs. Responsibility — Critical Distinction

CRITICAL: ACCOUNTABILITY cannot be delegated — it always stays with the person who originally assigned the task. RESPONSIBILITY can be delegated to others, but the delegator remains accountable for the outcome. On the exam, Accountability = single person; Responsibility = may be multiple people.

RACI Matrix

Letter	Role	Key Rule	Count	Example
R — Responsible	Does the actual work involved	Carries out the task	Multiple OK	Developers writing security code
A — Accountable	Ultimate owner. Cannot be delegated.	Signs off / owns the outcome	Only ONE	Project sponsor / CISO

C — Consulted	Provides subject matter expertise and input	Two-way communication	Multiple OK	Legal counsel, security architects
I — Informed	Receives status updates; does NOT provide input	One-way communication	Multiple OK	Executives, end users, auditors

Span of Control & Delegation

Span of Control	The number of subordinates a manager can effectively supervise. Best practice: fewer than 10 direct reports.
Delegation	Responsibility CAN be delegated. Accountability CANNOT. The delegator is always ultimately accountable.
ISACA Ethics	Support standards compliance; serve stakeholders lawfully; maintain confidentiality (unless law requires disclosure); maintain competency; inform on results.

Domain 1B — Information Security Strategy & Planning

Strategy Development Process

1	**Current State Assessment** — Inventory assets; identify vulnerabilities and threats; evaluate existing controls. This establishes the BASELINE.
2	**Define Desired State** — Complete future snapshot of security: principles, policies, frameworks, processes, people, technology. Use COBIT or BMIS to help define it.
3	**Gap Analysis** — Compare current state vs. desired state. Identify what is missing or insufficient. Work BACKWARD from desired state to current state.
4	**Build Roadmap** — Outline short- and long-term projects (involving people, processes, technology) to bridge the gap. Include milestones for mid-course correction.
5	**Define Resources & Constraints** — Resources: policies, standards, architectures, controls, personnel, tools. Constraints: budget, culture, legal requirements, org structure, risk appetite.
6	**Implement & Monitor** — Execute projects on roadmap. Monitor with KPIs, KRIs, KGIs. Use CMMI for maturity progression. Report in business terms to senior leadership.

Key Strategy Metrics

KGI — Key Goal Indicator	Defines what success looks like. The ENDPOINT. Example: achieving SOX compliance, reducing incidents by 30%.
KPI — Key Performance Indicator	Measures PROGRESS toward KGIs. Example: % of controls tested, patch compliance rate, mean time to detect.
CSF — Critical Success Factor	Essential elements required to achieve InfoSec management outcomes aligned with business goals. KPIs measure CSFs quantitatively.
Balanced Scorecard	Strategic planning tool measuring performance across 4 perspectives: Financial, Customer, Internal Processes, Learning & Growth.

Common Planning Biases — Avoid These!

Bias	Description	Risk to Strategy
Overconfidence	Overestimating ability to predict outcomes	Overly precise estimates; missing black-swan events
Optimism	Natural tendency to forecast positive outcomes	Underestimates challenges and risks; unrealistic projections

Anchoring	Initial figures unduly influence later judgments	Forecasts based on outdated or irrelevant data
Status Quo Bias	Reluctance to change familiar methods	Discourages innovation and necessary strategic shifts
Mental Accounting	Compartmentalizing funds by source/purpose	Inconsistent financial decisions; distorted spending
Herding Instinct	Conforming to popular trends for social validation	Adopting strategies because they're popular, not because they're best
False Consensus	Assuming others share your views	Overlooking critical risks; flawed plans persist

Action Plan Components

SWOT Analysis	Strengths (internal advantages) | Weaknesses (internal gaps) | Opportunities (external factors to leverage) | Threats (external factors that could harm). Guides where to invest in controls.
Gap Analysis	Performed for strategy components: maturity levels, control objectives, risk. Works BACKWARD from desired state. Repeated regularly for mid-course corrections.
Plans of Action	Implementation requires projects and initiatives. Each project has measurable milestones. Avoid point solutions and "firefighting" — integrate tactical with long-term goals.
Business Alignment	Understand org mission, goals, objectives, strategic approach, culture, asset value, regulatory requirements. Security must ENABLE business, not just restrict it.

Domain 1B — Governance Frameworks — COBIT, BMIS & More

COBIT — IT Management & Governance Framework

> **NOTE:** COBIT is maintained by ISACA. It provides best practices for IT Governance and Management, helping organizations align IT activities with business goals and ensuring IT resources are used effectively.

COBIT Principle	Description
1. Meeting Stakeholder Needs	Align security and IT with the needs of all relevant stakeholders
2. Covering the Enterprise End-to-End	Encompasses the entire enterprise — not just the IT function
3. Applying a Single Integrated Framework	One coherent framework — eliminates siloed approaches
4. Enabling a Holistic Approach	People, process, and technology viewed as an integrated system
5. Separating Governance from Management	Strategic oversight is distinct from day-to-day operations

BMIS — Business Model for Information Security

Org Design & Strategy	Defines business goals, missions, and how resources/roles interact. Must adapt to internal/external factors.
People	Human element of strategy. HR/security issues, roles, responsibilities. Must account for behaviors, biases, and training.
Process	Formal/informal mechanisms to get work done, including risk and compliance. Must align with business requirements.
Technology	Tools, infrastructure, applications that enhance processes. Always changing; introduces its own risks.
Dynamic Interconnections	Six "tensions" affecting security equilibrium: Governance, Culture, Enabling & Support, Emergence, Human Factors, Architecture.

Enterprise Risk Management (ERM) Frameworks

Framework	Focus	Key Feature
COSO ERM	Integrated risk management with standardized risk language	Common definitions, terms, and concepts for talking about risk across an org

ISO 31000:2018	Principles, framework, and process for managing risk	Helps identify opportunities AND threats; enterprise-wide, not IT-specific
BS 31100	Practical process aligned with ISO 31000	Identify, assess, respond, report, and review risks — aligned with ISO 31000

Architecture Frameworks

Framework	Type	Purpose
TOGAF	Enterprise Architecture	Links business processes with technology; defines target/reference architecture
Zachman Framework	Enterprise Architecture	Organizes architecture by different stakeholder perspectives (rows) and abstractions (columns)
E2AF	Extended Enterprise Architecture	Connects business design with security requirements across extended enterprise
EISA	Info Security Architecture	Part of broader enterprise architecture; includes conceptual, logical, physical, and operational perspectives

Domain 1 — Access Control, AAA & Accountability

CRITICAL: ACCOUNTABILITY is the overarching principle of access control. To achieve accountability, users must be uniquely IDENTIFIED, properly AUTHENTICATED, properly AUTHORIZED, and ALL ACTIONS must be LOGGED.

The 5-Step AAA Process — In Order

1	2	3	4	5
Identification	Authentication	Authorization	Auditing	Accounting

1 — Identification	Claiming an identity. Entering a username. No proof yet — just a claim. "I am user jsmith."
2 — Authentication	PROVING the claimed identity. Password, biometrics, smart card, certificate. Something you know / have / are.
3 — Authorization	Granting access to resources based on verified identity AND permissions (ACL, RBAC, etc.). What are you ALLOWED to do?
4 — Auditing	Tracking and recording user activity: log entries, resource usage, session recordings, failed attempts.
5 — Accounting	Reviewing logs and recorded actions to ensure policy compliance and detect anomalies or violations.

Five Pillars of Cybersecurity

1	2	3	4	5
Confidentiality	Integrity	Availability	Authentication	Nonrepudiation

NOTE: CIA Triad = the first 3 pillars. The full 5 pillars add Authentication and Nonrepudiation. All three CIA elements focus on protecting DATA within systems.

SSO vs. Federated Identity Management (FIM)

SSO — Single Sign-On	FIM — Federated Identity Management
Single organization scope	Cross-organization scope

Authenticate ONCE → access many systems within same org without re-authenticating	Authenticate ONCE → access systems ACROSS multiple orgs using a single digital identity
Enabled by: SAML, Kerberos, OIDC	High-level concept. Used in: SAML, OIDC, OpenID

Domain 1 — Authentication & Authorization Protocols

CRITICAL: CRITICAL EXAM DISTINCTION: OAuth 2.0 alone is AUTHORIZATION (access delegation) — NOT authentication/login. OIDC is the authentication layer BUILT ON TOP of OAuth 2.0. "Sign in with Google" = OIDC. "Let this app access your Google Drive" = OAuth 2.0. Without OIDC, OAuth2 cannot do login.

Protocol Reference Table

Protocol	Type	Description	Use Case
OpenID (legacy)	Authentication	Legacy protocol allowing one identity to log into multiple websites. Replaced by OIDC.	Logging into blogs/forums with your OpenID account instead of creating new accounts each time
OAuth 1.0	Authorization	Allows a user to let a 3rd-party app access their data WITHOUT sharing their password.	Calendar app accesses your Flickr photos — you authorize access but don't give Flickr credentials
OpenID Connect (OIDC)	Authentication (on OAuth 2.0)	Modern auth protocol BUILT on OAuth 2.0. Lets users log in using accounts from Google, Microsoft, etc.	"Sign in with Google" on a shopping site — OIDC confirms your identity via Google's system
OAuth 2.0	Authorization	Updated framework for secure, token-based authorization of 3rd-party access to user data.	Letting a 3rd-party app access your Google Drive files without giving it your Google password
SAML 2.0	Authentication (XML-based)	XML-based standard enabling SSO across enterprise web applications. Common in enterprise federation.	Using corp credentials to access Salesforce (external SaaS) — classic enterprise SSO scenario
Kerberos	Authentication (ticket-based)	Ticket-based auth using a KDC (Key Distribution Center). Mutual authentication — both client AND server verified.	Windows Active Directory environments. Client requests ticket; KDC grants TGT; service issues session ticket

Authentication Factor Types

Factor	Type	Examples	Strength
Something you KNOW	Type 1	Password, PIN, passphrase, security questions	Weakest — can be guessed, phished, or stolen
Something you HAVE	Type 2	Smart card, hardware token (RSA SecurID), USB key, OTP via phone	Medium — can be lost or stolen but requires physical possession

Something you ARE	Type 3 (Biometrics)	Fingerprint, retina scan, voice, facial recognition	Strong — unique to individual; FRR and FAR tradeoffs
Somewhere you ARE	Type 4 (Location)	GPS location, IP address, network segment	Supplementary — used in contextual/adaptive auth
Something you DO	Type 5 (Behavior)	Typing cadence, mouse movement patterns	Emerging — used in behavioral biometrics and continuous auth

5 Elements of a Complete Security Mechanism (AAA)

> **NOTE:** Memorize: Identification → Authentication → Authorization → Auditing → Accounting. These five elements in order constitute a complete and accountable access control mechanism.

Access Control Models

Model	Acronym	How It Works	Best For
Mandatory Access Control	MAC	Labels and clearances — the SYSTEM decides access based on sensitivity labels. Users cannot change permissions.	Government/military environments requiring strict need-to-know (e.g., DoD)
Discretionary Access Control	DAC	Resource OWNER decides who gets access. ACLs controlled by the data owner. Most flexible but least secure.	Commercial environments; standard file permissions in Windows/Linux
Role-Based Access Control	RBAC	Access granted based on ROLE (job function), not individual identity. Permissions tied to roles, roles assigned to users.	Enterprise environments; simplifies provisioning and de-provisioning
Rule-Based Access Control	RuBAC	Access decisions based on a set of rules (e.g., firewall rules). Rules defined by admin, not by user identity.	Network devices (firewalls, routers); time-based or condition-based access
Attribute-Based Access Control	ABAC	Access decisions based on attributes of user, resource, AND environment. Most flexible and fine-grained.	Cloud environments; complex authorization scenarios requiring context

Domain 2 — Risk Management — Concepts, Formulas & Process

Core Risk Terminology

Asset (AV)	Something valuable you want to protect. Asset Value = total monetary value of the asset. Foundation of all risk calculations.
Threat	A possible danger that could harm an asset by exploiting a vulnerability. Can be natural, human, or environmental.
Vulnerability	A weakness in an asset or system that a threat can exploit. Technical, procedural, physical, or human.
Risk	The probability that a threat will successfully exploit a vulnerability AND the resulting impact. Risk = Threat × Vulnerability × Impact.
Likelihood	The probability that a threat will successfully exploit a vulnerability within a given time period.
Impact	The damage or cost caused if a risk becomes real. Can be financial, reputational, operational, or legal.
Exposure	The condition of being open to threats — being at risk of attack without yet being attacked.
Exploit	A specific method used to take advantage of a vulnerability during an attack.
Threat Actor	The person, group, or entity that carries out the attack. Can be internal (insider) or external.
Control / Safeguard	A security feature or practice used to REDUCE risk by fixing vulnerabilities or blocking threats.
Countermeasure	A tool or method that reduces the EFFECT or impact of an attack after the fact.
Inherent Risk	The risk level BEFORE any controls are applied. The raw, unmitigated risk.
Residual Risk	Risk that REMAINS after applying controls. The organization must accept this level of risk.
Acceptable Risk	Level of residual risk the org is willing to tolerate based on risk appetite and cost/benefit analysis.
Attack Surface	All possible vulnerabilities and points a threat actor can target in a system or org.

Risk Formulas — Must Memorize!

Formula	Components	Purpose

SLE = AV × EF	AV = Asset Value EF = Exposure Factor (% of asset lost per single incident)	Single Loss Expectancy: expected loss from ONE occurrence of the threat
ALE = SLE × ARO	SLE = Single Loss Expectancy ARO = Annualized Rate of Occurrence (# of times per year)	Annual Loss Expectancy: total expected yearly loss from a given risk
Decision: Cost of Control vs ALE	If cost of control < ALE → Implement the control If cost of control > ALE → Accept the risk (cheaper to absorb)	Drives cost-effective control selection and risk treatment decisions

General Risk Management Process (ISO 31000 — 7 Steps)

1	**Categorize** — Assets, systems, and data. Understand what you are protecting and its value/sensitivity.
2	**Conduct Risk Assessment** — Identify threats, identify vulnerabilities, determine likelihood and impact for each asset-threat pair.
3	**Select Risk Treatment** — Choose how to address each risk: Accept, Avoid, Transfer (insurance), or Mitigate (apply controls).
4	**Implement Controls** — Deploy the selected safeguards, countermeasures, and procedural controls.
5	**Assess Effectiveness** — Test and evaluate whether controls are working as intended and reducing risk to acceptable levels.
6	**Authorize Controls** — Formally authorize the risk treatment decisions and document accepted residual risk.
7	**Monitor and Review** — Continuously monitor the risk environment; repeat the process as threats, assets, and controls change.

Risk Assessment vs. BIA — Critical Distinction

Risk Assessment	Business Impact Analysis (BIA)
Identifies WHAT CAN GO WRONG	Identifies WHAT MATTERS MOST
Focuses on threats, vulnerabilities, likelihood, and impact	Focuses on critical business functions and the cost/consequence of their disruption
Output: Risk register; risk scores; control recommendations	Output: RTO, RPO, MTD values; recovery priorities
Drives: Control selection for assets	Drives: Recovery strategy priorities (used in BCP/DRP)

Risk Treatment Options

Option	Also Called	Description	Example

Accept	Risk Tolerance / Retention	Acknowledge the risk and choose to live with it. Appropriate when cost of control exceeds ALE.	Accept the low risk of a power outage affecting a non-critical system
Avoid	Risk Elimination	Stop the activity that creates the risk entirely.	Don't collect SSNs you don't need — eliminates the data breach risk
Transfer	Risk Sharing	Shift the financial impact to a third party (insurance, contracts).	Purchase cyber liability insurance; include indemnity clauses in vendor contracts
Mitigate	Risk Reduction	Implement controls to reduce likelihood or impact to acceptable level.	Deploy MFA, encryption, and IDS to reduce probability and impact of breach

Domain 2 — Threat Modeling — STRIDE, PASTA, DREAD, VAST, TRIKE

Three Threat Modeling Focuses

Asset Focus	Attacker Focus	Software Focus
What valuable assets could be attacked? Start with what you want to protect.	Who are the threat actors? What are their capabilities, motivations, and targets?	Where are the weaknesses in the application/system? STRIDE and PASTA are software-focused.

Threat Modeling Frameworks

Model	Developed By	Focus	Key Components / Acronym
STRIDE	Microsoft	Software/application threat modeling	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege
PASTA	Various	Risk-centric, 8-step process (Process for Attack Simulation and Threat Analysis)	1.Define Objectives 2.Technical Scope 3.App Decomposition 4.Threat Analysis 5.Vuln Analysis 6.Attack Simulation 7.Risk Analysis 8.Mitigation
DREAD	Microsoft (legacy)	Threat prioritization scoring model	Damage potential, Reproducibility, Exploitability, Affected Users, Discoverability
VAST	ThreatModeler	Integrates threat management into Agile DevOps processes	Visual, Agile, Simple, Threat — designed for scale and automation in CI/CD pipelines
TRIKE	Open Source	Acceptable risk — ensures assigned risk per asset is acceptable to stakeholders	Requirements Model-based. Stakeholder-driven risk acceptance. Open source tool available.

Threat Modeling Process (General 4 Steps)

1	**Identify Threats** — Enumerate potential threats to assets using the chosen framework (STRIDE, PASTA, etc.)
2	**Enumerate and Diagram Potential Attacks** — Create attack trees or data flow diagrams showing how attacks could occur
3	**Perform Reduction Analysis** — Prioritize threats by likelihood and impact — focus on what matters most first
4	**Prioritize and Respond** — Select and implement mitigating controls for high-priority threats

Domain 7 — Business Continuity & Disaster Recovery

BCP vs. DRP — The Key Distinction

CRITICAL: BCP is the UMBRELLA — DRP is PART OF IT. BCP focuses on the WHOLE BUSINESS (communications, processes, people). DRP focuses on the TECHNICAL recovery of IT systems. BCP = Strategic. DRP = Tactical.

Dimension	BCP (Business Continuity Plan)	DRP (Disaster Recovery Plan)
Scope	Entire organization — all business functions	IT systems and technical infrastructure
Level	Strategic — the umbrella policy	Tactical — a component of BCP
Focus	Keeping critical business functions running	Restoring IT systems after a disruption
Includes	Crisis communications, alternate work locations, supply chain, personnel	System backups, failover, data recovery, RTO/RPO targets
First Step	Establish the Business Continuity POLICY	Conduct Business Impact Analysis (BIA)
Key Output	BCM framework, testing schedule, awareness program	Detailed recovery procedures for each IT system

Business Continuity Management (BCM) — 6 Steps

1	**Establish BC Policy** — FIRST AND FOREMOST. Define scope, objectives, and management commitment. This is the foundation.
2	**Conduct BIA** — Identify critical functions, quantify impact of disruption (AV, MTD, RTO, RPO), determine recovery priorities.
3	**Develop Recovery Strategies** — Hot/warm/cold sites; redundant systems; alternate processing arrangements; vendor agreements.
4	**Create the BCP** — Document the plan: scope, recovery procedures, roles, contacts, communication trees, escalation.
5	**Test, Train, and Maintain** — Tabletop exercises, walkthroughs, simulations, full interruption tests. Train all relevant staff.
6	**Continuously Improve** — Update after every test, incident, or major organizational change. Plan is a LIVING document.

Business Impact Analysis (BIA) — 5 Steps

1	**Identify Priorities** — Use quantitative measures (AV, MTD, RTO, RPO). Identify which functions are most critical to survival.
2	**Identify Risks** — Natural disaster, data breach, insider threat, system failure, supply chain disruption, cyber attack.
3	**Likelihood Assessment** — Determine ARO of each identified risk scenario. Historical data, threat intelligence.
4	**Impact Analysis** — Assess how disruptions affect operations: financial loss, reputation damage, legal exposure, safety risks.
5	**Resource Prioritization** — Prioritize PEOPLE first, then critical systems and resources needed for business recovery.

Key Recovery Metrics

RTO — Recovery Time Objective	Maximum acceptable time to restore a function or system after disruption. How FAST must you recover?
RPO — Recovery Point Objective	Maximum acceptable amount of data loss measured in time. How much data can you AFFORD to lose?
MTD — Maximum Tolerable Downtime	The longest period a business function can be unavailable before causing irreparable harm. RTO must be ≤ MTD.
WRT — Work Recovery Time	Time needed to verify and restore data integrity after systems are back online. RTO + WRT ≤ MTD.

Domain 2 — NIST Frameworks — RMF (800-37) & CSF

NIST RMF (SP 800-37) — 7 Steps — MANDATORY for Federal Agencies

Mnemonic: Prepare — Categorize — Select — Implement — Assess — Authorize — Monitor

1	**Prepare** — NEW in Rev 2. Establish context for RMF execution: assign roles, identify common controls, develop strategy. This is the step that makes NIST RMF 7 steps vs. the general 6-step RMF.
2	**Categorize** — Categorize the information system based on FIPS 199. Determine impact levels (Low/Moderate/High) for Confidentiality, Integrity, and Availability.
3	**Select** — Select appropriate security controls from NIST 800-53 based on FIPS 200 minimum requirements. Tailor as needed.
4	**Implement** — Implement the selected security controls. Document how controls are deployed in the system security plan (SSP).
5	**Assess** — Assess whether controls are implemented correctly and operating as intended. Per NIST 800-53A: 4 components — Specifications, Mechanisms, Activities, Individuals.
6	**Authorize** — Authorizing Official (AO) reviews and grants ATO (Authority to Operate). Accepts residual risk formally.
7	**Monitor** — Continuously monitor security controls; report status; respond to changes; reassess as needed. Ongoing process.

NIST RMF vs. NIST CSF vs. ISO 31000

Framework	Audience	Mandatory?	Structure	Purpose
NIST RMF (800-37)	US Federal Agencies	YES — mandatory for federal	7-step structured authorization process	System authorization; managing risk in federal info systems
NIST CSF	Private/Commercial sector	NO — optional guidance	Framework Core: Identify, Protect, Detect, Respond, Recover	Improving cybersecurity posture; identifying gaps; risk-based approach
ISO 31000:2018	Any organization worldwide	NO — voluntary standard	Principles, framework, process (continuous)	Enterprise-wide risk management; non-IT-specific

NIST SP 800-53A — Security Controls Assessment

NOTE: Under NIST 800-53A, assessments include FOUR components: (1) Specifications — documents associated with the system being audited; (2) Mechanisms — controls used within the info system to meet specifications; (3) Activities — actions carried out by people within the info system; (4) Individuals — people who implement specs, mechanisms, and activities.

Domain 2 — ISO/IEC Standards Quick Reference

ISO/IEC Security Standards

Standard	Name	Key Points
ISO 27001:2022	Information Security Mgmt System (ISMS) Requirements	Framework for establishing, maintaining, and improving an ISMS. 2022 update adds cloud security coverage. Requires management commitment and internal audit.
ISO 27002	Security Controls Guidelines	Detailed best practices for IMPLEMENTING ISO 27001 controls. Acts as a code of practice. Companion to 27001.
ISO 27005	Risk Management (InfoSec)	Risk analysis framework aligned with ISO 27001. Similar in scope to NIST 800-30. Covers risk identification, assessment, treatment, and acceptance.
ISO 31000:2018	Risk Management — Principles & Guidelines	Enterprise-wide, NON-IT-specific risk framework. Broader than 27005. Applies to all organizational risks, not just information security.
ISO 15408	Common Criteria for IT Security Evaluation	Evaluates security assurance of IT products. Uses EAL1-EAL7 levels. Has REPLACED TCSEC (Orange Book) and ITSEC.
ISO 9001	Quality Management Systems	Quality management; can complement security strategies. Relevant when integrating security into quality processes.

FIPS Standards

FIPS	Name	Purpose
FIPS 199	Security Categorization of Federal Information Systems	Determines sensitivity level: Low/Moderate/High for each CIA property. Input to NIST RMF Step 2 (Categorize).
FIPS 200	Minimum Security Requirements for Federal Info Systems	Specifies which NIST 800-53 control baselines apply based on FIPS 199 categories. Input to RMF Step 3 (Select).
FIPS 140-3	Security Requirements for Cryptographic Modules	Certification standard for hardware/software encryption modules. Levels 1-4 based on physical security and design requirements.

IEEE Standards

Standard	Name	Key Exam Points
IEEE 802.1X	Port-Based Network Access Control (NAC)	Used for network authentication. Often paired with RADIUS. Controls access at the network port level before granting network access.

IEEE 802.11	Wireless LAN Standards	Wi-Fi protocols. Know: WPA2 (CCMP/AES), WPA3 (GCMP/SAE), and that WEP is broken. 802.11ax = Wi-Fi 6.
IEEE 802.3	Ethernet Standards	Wired networking. Covers MAC addressing and CSMA/CD (Carrier Sense Multiple Access with Collision Detection).

Domain 2 — Data Classification — Government & Private Sector

Classification Levels Comparison

Government Level	Class	Private Sector Equivalent	Impact of Disclosure
Top Secret	**Class 3**	Confidential / Proprietary	Exceptionally grave damage to national/org security
Secret	**Class 2**	Private	Serious damage to national/org security
Confidential	**Class 1**	Sensitive	Damage to national/org security
Unclassified	**Class 0**	Public	No damage — public information

Asset Management & Classification Process

1	**Inventory Assets** — Identify and document all information assets — hardware, software, data, people, processes.
2	**Assign Asset Ownership** — Every asset must have a defined owner who is accountable for its classification and protection.
3	**Classify Assets** — Apply classification labels based on value, sensitivity, and criticality. Use org's classification policy.
4	**Apply Proportional Controls** — Controls must be cost-effective: protection cost should not exceed asset value (cost/benefit analysis).
5	**Monitor Assets and Controls** — Continuously monitor asset status and control effectiveness. Update classification as sensitivity changes.
6	**Securely Decommission** — Properly dispose of assets. Follow NIST 800-88 for media sanitization. Destroy data beyond recovery.

Data Lifecycle — Classify on Creation!

1	2	3	4	5	6
Create & Classify	**Store**	**Use**	**Share**	**Archive**	**Destroy**

CRITICAL: Classify at CREATION — not later. Storage controls must match the classification. Destruction must render data UNREADABLE and UNRECOVERABLE to eliminate liability. Archive is often driven by legal/regulatory retention requirements.

Domain 3 — Security Models — Confidentiality & Integrity

Security Models Overview

Confidentiality Models	Integrity Models
Bell-LaPadula — No Read Up / No Write Down	Biba — No Read Down / No Write Up
Brewer-Nash (Chinese Wall) — Prevent COI	Clark-Wilson — Access control triple
Take-Grant — 4 operations: take, grant, create, revoke	Goguen-Meseguer — THE noninterference model
	Sutherland — Preventing interference (info flow + SMM)

Bell-LaPadula Model — Confidentiality

NOTE: Bell-LaPadula: NO READ UP ("Simple Security Property") — NO WRITE DOWN ("Star * Security Property"). Think: classified info flows UP (more people can't see it) never DOWN (can't declassify by writing it lower). Used by DoD for MAC access. Simple Property = READ. Star Property = WRITE.

Simple Security Property	A subject CANNOT read data at a HIGHER classification level than their clearance. "No Read Up." Protects confidentiality upward.
Star (*) Security Property	A subject CANNOT write data to a LOWER classification level than the current object. "No Write Down." Prevents downgrading secrets.
Discretionary Security Property	Uses an access matrix to specify discretionary access controls. The DAC component of Bell-LaPadula.
Used For	DoD Mandatory Access Control. Multilevel security. Preserves CONFIDENTIALITY. State Machine Model and Information Flow Model.

Biba Model — Integrity

CRITICAL: Biba is the OPPOSITE of Bell-LaPadula. BLP: No Read Up / No Write Down. Biba: No Read DOWN / No Write UP. The "i" in Biba stands for Integrity. Think: you don't read LOW integrity data (it could corrupt your work) and you don't write to HIGH integrity systems (you'd corrupt them).

Simple Integrity Property	A subject CANNOT read data at a LOWER integrity level. "No Read Down." Protects from corruption via low-quality sources.
Star (*) Integrity Property	A subject CANNOT write data to a HIGHER integrity level. "No Write Up." Prevents contaminating high-integrity data.

Invocation Property	A subject cannot invoke (call) a subject at a higher level of integrity.
Used For	Commercial integrity protection. State Machine Model (SMM). Also an Information Flow Model like Bell-LaPadula.

BLP vs. Biba — Side-by-Side Comparison

Property	Bell-LaPadula (Confidentiality)	Biba (Integrity)
Simple Property (READ)	No Read UP (can't read higher classification)	No Read DOWN (can't read lower integrity)
Star (*) Property (WRITE)	No Write DOWN (can't write to lower classification)	No Write UP (can't write to higher integrity)
Goal	Protect CONFIDENTIALITY — keep secrets secret	Protect INTEGRITY — keep data accurate and trustworthy
Environment	Government/military MAC environments	Commercial environments requiring data accuracy
Model Type	State Machine Model; Information Flow Model	State Machine Model (SMM); Information Flow Model

Other Security Models

Model	Type	Key Concept
Clark-Wilson	Integrity (commercial)	Lattice-based. Access control triple (subject → program → object). Separation of duties. CDI (constrained data items) only modified via TPs (transformation procedures).
Brewer-Nash (Chinese Wall)	Confidentiality	Prevents Conflict of Interest (COI). Once a subject accesses data from one company, they cannot access data from competitors. Used in financial consulting.
Take-Grant	Confidentiality	Uses a directed graph. Four operations: TAKE rights, GRANT rights, CREATE objects/subjects, REVOKE rights. Analyzes how access rights propagate.
Graham-Denning	Both	Formal protection rules. Each object has an OWNER and CONTROLLER. Focused on SECURE CREATION and DELETION of subjects and objects. Eight rules (create obj/subj, delete obj/subj, read/grant/delete/transfer rights).
Goguen-Meseguer	Integrity	THE noninterference model. Subjects at one security level should not be able to see or affect what subjects at another level are doing.
State Machine Model	Foundation	System is ALWAYS SECURE regardless of its state. Based on Finite State Machine (FSM). A "state" is a snapshot at a point in time. If every state transition results in a secure state → secure state machine. Biba and BLP are both based on SMM.

Domain 3 — Common Criteria & Evaluation Standards

CRITICAL: Common Criteria (CC / ISO 15408) has REPLACED both TCSEC (Orange Book) and ITSEC. TCSEC was confidentiality-ONLY. ITSEC covered confidentiality AND integrity and supported networked devices. CC combines both and provides international standard evaluation.

Common Criteria Key Terms

Protection Profile (PP)	A set of security requirements for a SPECIFIC CATEGORY of product (e.g., "smart card PP"). Community-created. Black box evaluation.
Target of Evaluation (TOE)	The specific product or system being evaluated/certified.
Security Target (ST)	The VENDOR's security claims for their specific product. White box evaluation.
Security Functional Requirements	What the product must do (functional capabilities).
Security Assurance Requirements	How confidently those functions have been implemented and tested.
EAL — Evaluation Assurance Level	Scale from EAL1 (lowest — functionally tested) to EAL7 (highest — formally verified design). Most COTS products target EAL4.

Evaluation Assurance Levels (EAL1–EAL7)

EAL Level	TCSEC Equiv.	ITSEC Equiv.	Description	Testing Method
EAL 1	D	E0	Functionally Tested	Basic functional testing only
EAL 2	C1	E1	Structurally Tested	Analysis of security functions + independent testing
EAL 3	C2	E2	Methodically Tested & Checked	Developer testing + evaluation team confirms
EAL 4	B1	E3	Methodically Designed, Tested & Checked	Highest level achievable for most COTS products
EAL 5	B2	E4	Semi-Formally Designed & Tested	Semi-formal design representation + independent testing
EAL 6	B3	E5	Semi-Formally Verified Design & Tested	Structured development + formal model verification

EAL 7	A1	E6	Formally Verified Design & Tested	Highest level — complete formal verification; reserved for extreme risk environments

TCSEC (Orange Book) Quick Reference

Level	Class	Description
D	Minimal Protection	Failed or not tested. No security mechanisms.
C1	Discretionary Security Mechanisms	Weak protection mechanisms. Basic DAC.
C2	Controlled Access Protection	Strict login procedures. Object reuse protection. Audit trails.
B1	Labeled Security Protection	Mandatory access controls. Security labels on all subjects/objects.
B2	Structured Security Protection	Security labels + verification of no covert channels.
B3	Security Domains	Trusted path. Highly resistant to penetration. Covert channel analysis.
A1	Verified Design	Formal design verification. Highest TCSEC level.

Domain 8 — Key Lifecycles — Incident Response, SDLC, IAM

Incident Response (NIST SP 800-61) — 7 Steps

Mnemonic: Detection — Response — Mitigation — Reporting — Recovery — Remediation — Lessons Learned

1	**Detection** — Monitoring tools (IPS/IDS), user reports, help desk. Identify that an incident has occurred. MOST IMPORTANT step.
2	**Response** — Triage — is this REALLY an incident? Activate IR team. Initial damage limitation.
3	**Mitigation** — First containment effort. Create/activate IR team. Contain the incident to prevent further damage.
4	**Reporting** — Report to relevant stakeholders: management, legal, regulatory bodies (if required). Management decisions occur here.
5	**Recovery** — Return systems to business-as-usual operations. Restore from clean backups if needed.
6	**Remediation** — Root Cause Analysis (RCA). Find AND FIX the underlying cause that allowed the incident to occur.
7	**Lessons Learned** — Document what happened, what worked, what didn't. Update IR plan to prevent recurrence and improve process.

Software Development Lifecycle (SDLC)

Mnemonic: "Real Developers Ideas Take Effort" = Requirements, Design, Implementation, Testing, Evolution

SDLC Model	Structure	Key Characteristics	Weakness
Waterfall	Sequential, 7 stages	Analysis and design for the ENTIRE project upfront. Each stage feeds the next. Can return to previous stage for corrections.	Lacks feedback loops. Changes are costly and difficult once past design stage.
Agile	Iterative sprints	4 principles: Individuals & interactions; Working software; Customer collaboration; Responding to change. Scrum, Kanban, XP are Agile methods.	Less formal documentation. Harder to predict final cost/timeline. Scope creep risk.

Spiral	Iterative waterfall loops	"Metamodel" — model of models. Each loop produces a new prototype. 4 quadrants: Objectives, Alternatives, Development, Planning. Risk-driven.	Complex and expensive. Not suitable for small projects. Requires strong risk assessment skills.

Identity & Access Provisioning Lifecycle

1	2	3
Creation / Provisioning	**Manage / Review / Modify**	**Remove / Deprovision**

CRITICAL: Accounts should be DEPROVISIONED PROMPTLY on separation. Delayed deprovisioning is a leading cause of insider threat from former employees.

Vulnerability Assessment & Pentest Process

1	**Planning (Pre-Engagement)** — Define scope, rules of engagement, authorization, testing methodology, and timeline.
2	**Reconnaissance / Discovery** — PASSIVE information gathering. OSINT, DNS lookups, WHOIS. No direct contact with target systems.
3	**Enumeration** — ACTIVE scanning and probing. Port scanning, service detection, OS fingerprinting. Direct contact with target.
4	**Vulnerability Analysis** — Match known vulnerabilities with discovered systems. Use CVE database, vulnerability scanners (Nessus, OpenVAS).
5	**Attack / Exploitation** — ONLY FOR PENETRATION TESTING (not pure vulnerability assessment). Attempt to exploit discovered vulnerabilities.
6	**Document / Report Results** — Document all findings, evidence, severity ratings, and remediation recommendations.

Change Management Process

1	**Request the Change** — Formal change request submitted with justification, impact assessment, and rollback plan.
2	**Review the Change** — Technical and business review of the proposed change by relevant stakeholders.
3	**Approve / Reject** — Change Advisory Board (CAB) or designated authority approves or rejects. Major changes may require executive sign-off.
4	**Build / Test the Change** — Develop and test in a non-production environment. Validate rollback procedures.

5	**Notify Stakeholders** — Communicate change schedule to affected parties. Maintenance windows, service impacts.
6	**Schedule / Implement** — Implement during approved maintenance window. Monitor closely during and after.
7	**Document the Change** — DOCUMENT AT EVERY STEP. Update CIs in CMDB, update network diagrams, update runbooks.
8	**Validate Effectiveness** — Post-implementation review. Did the change achieve its objective? Any unintended consequences?
9	**Version and Baseline** — Update system baselines to reflect the new configuration. Version control all changed items.

Domain 1 — Capability Maturity Models — CMM, SAMM, RMM, IDEAL

Capability Maturity Model (CMM/CMMI) — IRDMO

Mnemonic: IRDMO — "I Rarely Do My Optimization"

Level	Name	Characteristics	Key Indicator
1	Initial (Ad Hoc)	Unpredictable and reactive processes. Security is fire-fighting. No formal processes.	Chaos, heroics, and one-off solutions
2	Repeatable	Basic processes exist and can be repeated. Some project management discipline.	Can repeat past successes on similar projects
3	Defined (Controlled)	Processes are documented, standardized, and communicated org-wide.	Documented procedures; consistent execution
4	Managed	Processes are measured and controlled quantitatively. Metrics-driven.	Data collection; statistical process control
5	Optimized	Continuous improvement based on metrics and feedback. Proactive optimization.	Innovation; process improvement is systematic

Consolidated Maturity Models Comparison

Model	Focus	Levels / Structure	Key Feature
CMM / CMMI	Software/process capability	5 levels: Initial → Optimized (IRDMO). Now maintained by ISACA.	Most widely recognized maturity model. Used for process assessment.
SAMM (Software Assurance Maturity Model)	Software security	3 levels per practice: Initial Implementation → Structured Realization → Optimized Operation	5 business functions: Governance, Design, Implementation, Verification, Operations
RMM (Risk Maturity Model)	Risk management	5 levels: Ad Hoc → Optimized (APDIO)	Measures maturity of risk management practices specifically
IDEAL Model	Software improvement	5 phases: Initiating, Diagnosing, Establishing, Acting, Learning	Implements SW-CMM attributes. Provides actionable improvement roadmap.

IDEAL Model Phases

I — Initiating	Business reasons outlined. Infrastructure and executive support secured. Problem/opportunity defined.

D — Diagnosing	Engineers analyze current org state and make specific, data-driven change recommendations.
E — Establishing	Org takes recommendations and develops a concrete plan to implement them. Priorities set.
A — Acting	Plan is put into action. Solutions are developed, tested, refined, and implemented.
L — Learning	Organization continuously analyzes outcomes and proposes actions to drive better future results.

Domain 4 — OSI Model & Network Protocols

OSI Model — All 7 Layers with Protocols

Mnemonic (top-down): "All People Seem To Need Data Processing"

Layer	Name	PDU	Key Protocols & Technologies
7	**Application**	Data	HTTP, HTTPS, FTP, SSH, SMTP, SNMP, DNS, Telnet, TFTP, POP3, IMAP, NNTP, S-RPC
6	**Presentation**	Data	SSL/TLS (negotiation phase), ASCII, EBCDIC, MIME, JPEG, MPEG, TIFF, MIDI, encryption/compression
5	**Session**	Data	SMB, RPC, NFS, SQL, NetBIOS — establishes, manages, and terminates sessions
4	**Transport**	Segment	TCP (connection-oriented, reliable), UDP (connectionless), SSL/TLS (data protection), SPX
3	**Network**	Packet	IP, ICMP, OSPF, BGP, RIP, IGMP, IPSec, NAT, SKIP, IPX — logical addressing & routing
2	**Data Link**	Frame	Ethernet (MAC), ARP, SLIP, PPP, L2F, L2TP, PPTP, FDDI, ISDN, 802.1X — MAC addressing
1	**Physical**	Bit	EIA/TIA-232, EIA/TIA-449, X.21, HSSI, SONET, Bluetooth, 802.11 (Wi-Fi), 802.3 (Ethernet)

Key Network Security Protocols

Protocol	Port	Layer	Purpose
SSH	22/TCP	7 (App)	Secure remote shell. Encrypts all traffic. Replaces Telnet (23) and rlogin.
HTTPS	443/TCP	7 (App)	HTTP over TLS. Encrypts web traffic. Certificate-based server authentication.
TLS/SSL	Varies	4/5/6	Transport Layer Security. Encryption in transit. TLS 1.3 is current standard. SSLv3 and TLS 1.0/1.1 deprecated.
IPSec	IP Proto 50/51	3 (Net)	VPN protocol suite. AH (Authentication Header) = integrity only. ESP (Encapsulating Security Payload) = encryption + integrity.
SNMP	161-162/UDP	7 (App)	Network management. SNMPv3 adds encryption and authentication. v1/v2 are insecure (cleartext community strings).
802.1X	N/A	2 (DL)	Port-based NAC. EAP authentication to network switch port or WAP. Works with RADIUS for authentication.

Domain ALL — Key Standards & Frameworks Quick Reference

NIST Special Publications Quick Reference

SP Number	Title	Exam Focus
800-12	Intro to Computer Security	General overview of security concepts
800-14	Generally Accepted Principles	8 principles for secure systems
800-18	System Security Planning Guide	SSP (System Security Plan) development
800-30	Risk Assessment Guide	HOW to conduct system-level risk assessments. Used at assessment step.
800-34	Contingency Planning Guide	DRP/BCP for federal IT systems. RTO, RPO, MTD definitions.
800-37	Risk Management Framework	7-step RMF: Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor.
800-53	Security & Privacy Controls	Control catalog for federal systems. 20 control families (AC, AU, CA, CM, CP, IA, IR, MA, MP, PE, PL, PM, PS, RA, SA, SC, SI, SR).
800-53A	Assessing Security Controls	4 assessment methods: Specifications, Mechanisms, Activities, Individuals.
800-57	Cryptographic Key Management	Key lifecycle: Generation, Distribution, Storage, Use, Rotation, Retirement/Destruction.
800-61	Incident Handling Guide	IR process: Detect, Respond, Mitigate, Report, Recover, Remediate, Lessons Learned.
800-88	Media Sanitization	Clear, Purge, Destroy. Methods for each media type. Destruction renders data unrecoverable.
800-115	Security Testing & Assessment	Pentest and VA methodology. Passive recon → active enum → vuln analysis → exploitation → reporting.
800-122	PII Confidentiality Guide	Protecting Personally Identifiable Information in federal systems.
800-145	Cloud Computing Definition	NIST definition of cloud: 5 characteristics, 3 service models, 4 deployment models.

EDRM — Electronic Discovery Reference Model

1	**Governance** — Information Governance policy creation — before anything else.

2	**Identification** — Determine what data is relevant to the legal matter.
3	**Preservation** — Safeguard relevant data from deletion, alteration, or spoliation (legal hold).
4	**Collection** — Acquire data from all identified relevant sources.
5	**Processing** — Isolate relevant content, deduplicate, convert formats for review.
6	**Review** — Examine data for relevance, privilege (attorney-client), sensitivity.
7	**Analysis** — Apply tools and techniques to extract patterns and facts from the data.
8	**Production** — Prepare data in court-appropriate format (Bates numbering, redactions).
9	**Presentation** — Present data as evidence in court proceedings, depositions, or hearings.

Domain ALL — Formulas, Mnemonics & Exam Tips

Critical Formulas

SLE = AV × EF	Single Loss Expectancy = Asset Value × Exposure Factor. One-time loss from one incident.
ALE = SLE × ARO	Annual Loss Expectancy = SLE × Annual Rate of Occurrence. Yearly expected loss.
Control Decision	If Control Cost < ALE → implement. If Control Cost > ALE → accept risk.
Residual Risk	Inherent Risk – Risk Mitigated by Controls = Residual Risk. Must be within risk appetite.

Key Mnemonics

Mnemonic	Stands For	Context
PCSIAAM	Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor	NIST RMF 7 steps (SP 800-37)
IRDMO	Initial, Repeatable, Defined, Managed, Optimized	CMM/CMMI 5 maturity levels
IDEAL	Initiating, Diagnosing, Establishing, Acting, Learning	IDEAL improvement model
STRIDE	Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege	Microsoft threat model
DREAD	Damage, Reproducibility, Exploitability, Affected Users, Discoverability	Threat prioritization scoring
RACI	Responsible, Accountable, Consulted, Informed	Roles in project/task management
CIA Triad	Confidentiality, Integrity, Availability	Core security objectives
AAA	Authentication, Authorization, Accounting (+ Identification + Auditing = 5 elements)	Access control completeness
BLP Rules	No Read Up (Simple) / No Write Down (Star)	Bell-LaPadula confidentiality model
Biba Rules	No Read Down (Simple) / No Write Up (Star)	Biba integrity model — OPPOSITE of BLP
SDLC	"Real Developers Ideas Take Effort" = Requirements, Design, Implementation, Testing, Evolution	Software development lifecycle
OSI top-down	"All People Seem To Need Data Processing" = App, Pres, Session, Transport, Net, DLink, Phys	OSI 7 layers from top (7) to bottom (1)

High-Frequency Exam Tips

EXAM TIP: GOVERNANCE vs. MANAGEMENT: Governance = board-level oversight (WHY/WHAT). Management = operational execution (HOW). Questions about "setting direction" or "risk appetite" → Governance. Questions about "implementing controls" or "day-to-day security" → Management.

CRITICAL: ACCOUNTABILITY: The word "accountability" on the CISSP exam almost always means it CANNOT be delegated. Accountability rests with the individual who originally assigned the task.

EXAM TIP: BCP vs. DRP: BCP = the whole business continuity umbrella (strategic). DRP = technical recovery of IT systems (tactical). DRP is PART OF BCP.

CRITICAL: OAUTH vs OIDC: If asked about AUTHENTICATION protocols, include OIDC and SAML. OAuth 2.0 alone is AUTHORIZATION — not authentication. "Sign in with X" = OIDC. "App accessing your data" = OAuth 2.0.

EXAM TIP: BLP vs. BIBA: Bell-LaPadula = CONFIDENTIALITY. No Read Up / No Write Down. Biba = INTEGRITY. No Read Down / No Write Up. They are OPPOSITES. BLP: keeps secrets from going DOWN. Biba: keeps integrity from going DOWN.

NOTE: RISK FORMULAS: ALE = SLE × ARO. SLE = AV × EF. Control is worth implementing if its ANNUAL COST < ALE. ARO of 0.1 means the event occurs once every 10 years.

EXAM TIP: COMMUNICATE IN BUSINESS TERMS: When asked what a CISO or security manager should do when presenting to the board, ALWAYS translate technical jargon into business language. Focus on risk reduction, cost savings, and regulatory compliance. A steering committee helps get business buy-in and executive endorsement.

NOTE: NIST RMF vs. CSF: RMF (800-37) = mandatory for US federal agencies. 7-step authorization process. CSF = optional for private sector. Both address risk management but for different audiences.

EXAM TIP: COMMON CRITERIA: CC has REPLACED TCSEC and ITSEC. EAL1 = lowest (functionally tested). EAL7 = highest (formally verified). Most commercial off-the-shelf products achieve EAL4.

Strategic vs. Tactical vs. Operational Plans

Level	Time Horizon	Question	CISSP Example
Strategic	3-5 years	"Where are we going?"	Creating a business continuity PROGRAM or security governance framework
Tactical	1-2 years	"What projects get us there?"	Building a Disaster Recovery Plan to support the BCP, implementing an ISMS

Operational	Daily / Weekly	"What tasks are we doing today?"	Implementing firewall rules, running backup schedules, applying patches, rotating keys

Compliance Type Quick Reference

Type	Examples	Enforced By
Legal	CCPA (California Consumer Privacy Act)	Laws passed by government. Applies broadly to all orgs in jurisdiction.
Regulatory	HIPAA, FERPA, SOX, GDPR, PCI-DSS	Regulatory bodies implementing laws. Industry and geographic scope.
Contractual	Vendor agreements, SLAs, ISO 27001 certification requirements	Legally binding agreements between orgs. Enforced through contract terms.